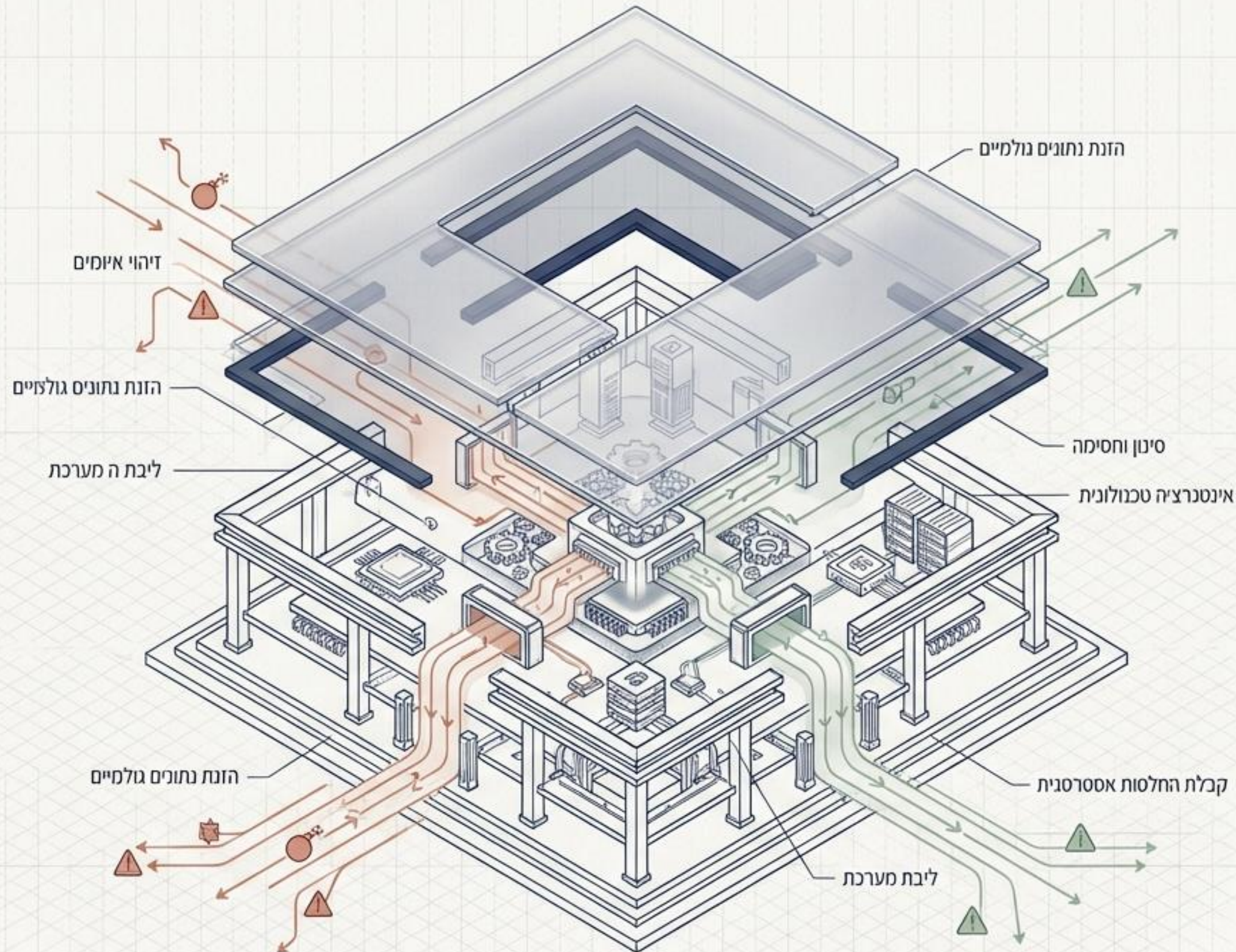


חמ"ל סייבר מודרני: האנטומיה, הטכנולוגיה והאסטרטגיה



Industry Breakdown: Who Are the Biggest Targets? — 2025 Cyber Risk Landscape

Healthcare — Highest Cost & Most Targeted



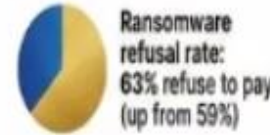
\$7.42M

avg. breach cost (U.S.) —
#1 for 14 consecutive years

→ Longest breach lifecycle: 279 days (vs. 241 global)



Mega breaches: only ~2% of cases → 76% of all healthcare records exposed



Ransomware refusal rate: 63% refuse to pay (up from 59%)

• Small hospitals pay 67% of the time; large systems pay 38-50%

Financial Services — Second Highest Cost Sector



\$5.56M

average breach cost

• 10% of all breaches occur in finance

→ Detection/containment improved: 233 days (global = 241)

• 2025: attempted \$130M Pix payment system heist

2025: attempted \$130M Pix payment system heist

Crypto/fintech exposures: 69,000 Coinbase users breached via insiders

Technology / High-Tech — Supply Chain Ripple Effects



~\$4M

average, but disproportionate downstream impact

• Salesforce OAuth compromise: data stolen from 91+ companies including Google, Cisco



Large-scale source code leaks (e.g., GitHub repo breaches)



High frequency of nation-state IP theft: chip designs, source code, sensitive architecture

Extortion without ransomware increasingly common

Manufacturing — Fastest-Growing Ransomware Target



61%

surge in ransomware attacks (2025)

• OT-targeted ransomware up 46% (Dragos 2025)

⚡ Downtime = severe revenue loss → high extortion pressure

Attacks often pivot from IT → OT via phishing or vulnerable legacy systems

Widespread PLC vulnerabilities being exploited

Retail & E-Commerce — High-Volume Data Theft & Extortion



Breach costs slightly below average, but highest incident frequency

• 2025 saw a spike in data-only extortion (leak threats > encryption)

Payment skimming (Magecart-style) remains widespread

Credential-stuffing attacks surge due to leaked password volumes
Customer trust impact severe: reputation loss → revenue drop

Government & Public Sector — State-Sponsored Threat Epicenter



Critical infrastructure breaches:
\$4.82M
average cost

• 2025 saw major state-sponsored campaigns: China's Salt Typhoon telecom infiltration, Russia's Midnight Blizzard breach of Microsoft, Iranian PLC exploitation targeting water facilities

86% of critical infrastructure entities fear state-backed attacks

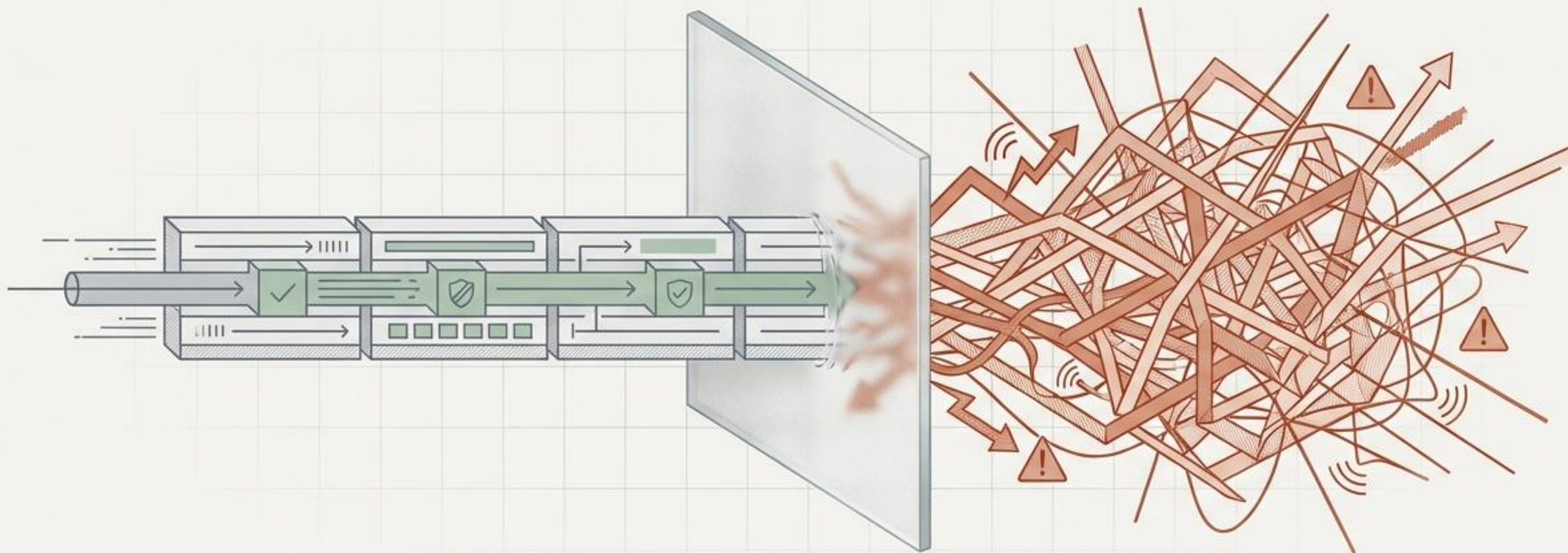
Legacy systems + tight budgets amplify risk

Zero Trust mandated across federal agencies

In 2025, attackers target sectors where downtime = leverage and data = currency. Healthcare, Finance, Manufacturing, and Government remain the highest-risk industries.



מהו הכאב? מעומס התראות לשליטה מבצעית



המטרה

להפוך נראות (Visibility) לפעולה, ולהתראות – להפחתת סיכונים משמעותית.

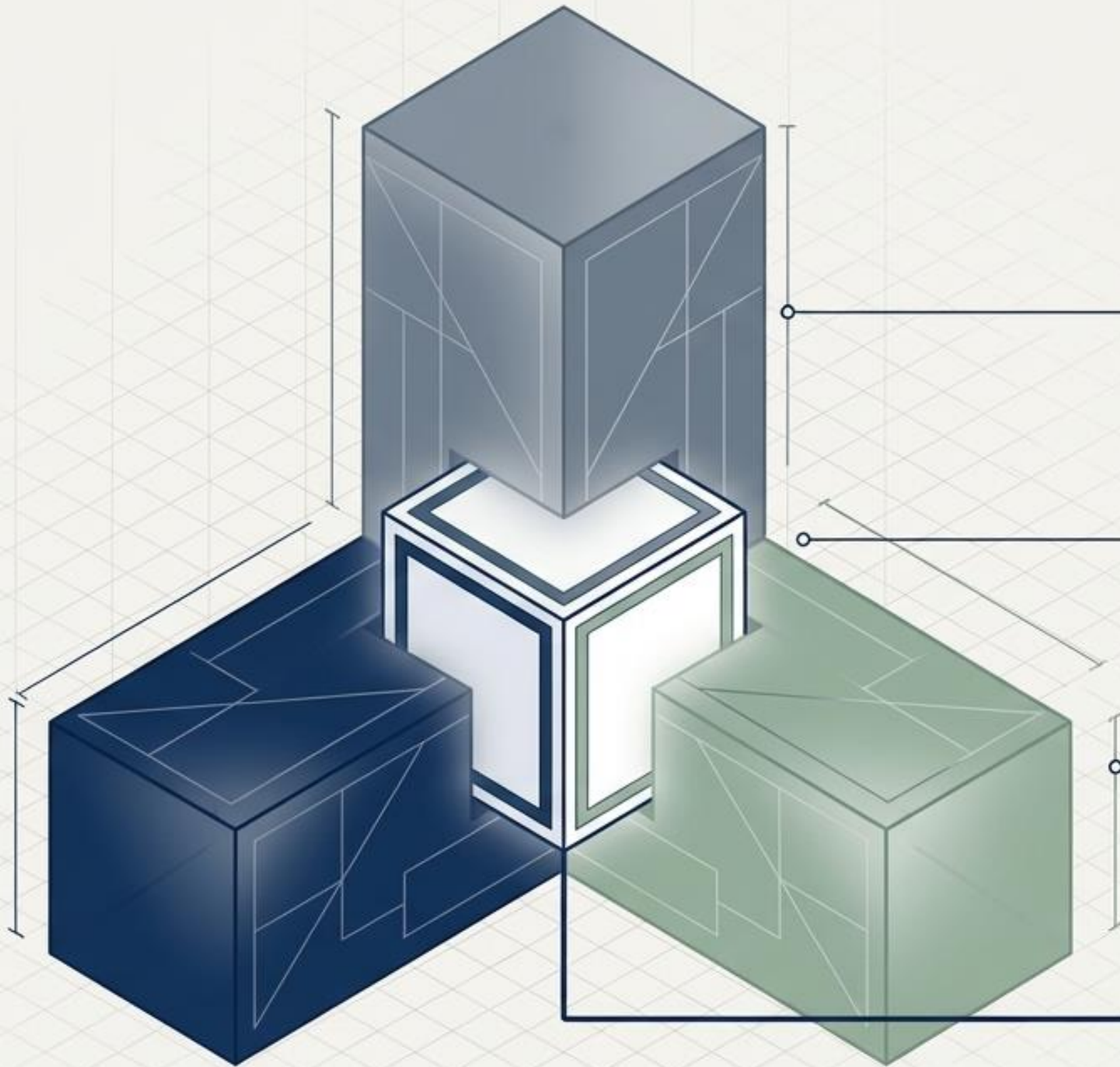
הפתרון (The SOC)

מרכז פעולות אבטחה (Security Operations Center) – פונקציה מבצעית ריכוזית המנטרת, מזהה, ומגיבה לאירועי סייבר 24/7 תוך הפחתת רעשי רקע.

הכאב (Alert Fatigue)

צוותי אבטחה לא מאורגנים טובעים ב-1,000 עד 3,000 התראות ביום, רובן התראות שווא (False Positives). התוצאה: שחיקת אנליסטים ופספוס איומים קריטיים.

'השילוש הקדוש' של אבטחת המידע



טכנולוגיה (Technology)

כלים כמו SIEM, SOAR ו-XDR המשמשים לאיסוף, אוטומציה וזיהוי מתקדם. טכנולוגיה ללא תהליך = עומס התראות.

תהליכים (Process)

מתודולוגיות סדורות (NIST) ותסריטי תגובה (Playbooks). תהליך ללא אוטומציה = איטיות ושגיאות אנוש.

אנשים (People)

אנליסטים וציידים איומים המחולקים לדרגים (Tiers). אנשים ללא כלים = שחיקה מהירה.

חמ"ל סייבר מודרני

הליבה: אבטחה אמיתית חיה בנקודת המפגש המדויקת של שלושתם.

סוגי תגובות

EDR

גילוי ותגובה
בנקודות קצה

- איסוף נתונים
- מנוע גילוי
- מנוע ניתוח נתונים
- מודיעין איומים
- התרעות ופורנזיקה
- שחזור עקבות
- תגובה אוטומטית

MDR

גילוי ותגובה
מנוהלים

- MDR מנוהל
- טלמטריית היקף
- ניהול ותגובה לא
- לאירועים
- שירות במיקור חוץ

NDR

גילוי ותגובה
ברשת

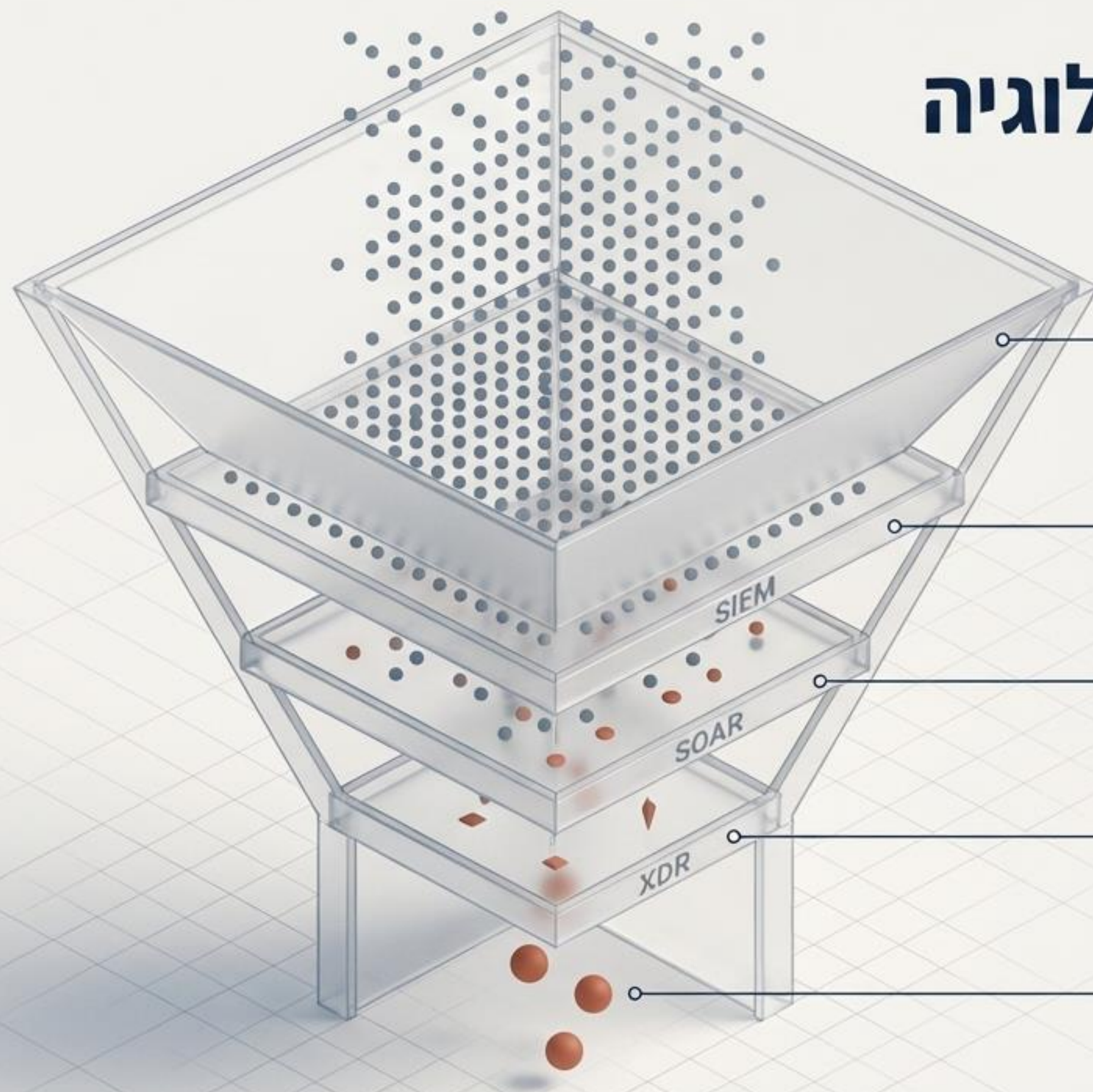
- יכולות גילוי ותגובה
- ברשת פנימית
- ניתוח התנהגותי
- בקרות אבטחה
- גילוי איומים פנימיים

XDR

גילוי ותגובה
מורחבים

- בקרות התקנים
- הצפנת דיסק
- חומות אש
- תיאום ואוטומציה
- ניתוח למידת מכונה
- של תעבורה פנימית
- פנימית וחיצונית

משפך ההתראות: טכנולוגיה כפילטר'אות מול רעש'



קלט (Data Sources) - מיליוני רשומות (Logs) מתחנות קצה, רשתות, ענן וזהויות.

קורלציה (SIEM) - ניתוח מרכזי והצלבת אירועים למציאת דפוסים.

אוטומציה (SOAR) - הפעלת Playbooks לטיפול אוטומטי ואיסוף מידע תומך.

פעולה (XDR) - זיהוי ותגובה מורחבת לבידוד איומים בזמן אמת.

פלט (Actionable Alerts) - קומץ התראות קריטיות המועברות לאנליסט אנושי.

פענוח ה-Tech Stack: מה ההבדל בין SOAR, SOAR ו-XDR?

	 SIEM	 SOAR	 XDR
מיקוד מרכזי	איסוף וניתוח לוגים, תאימות (Compliance).	אוטומציה של תגובות ותזמור תהליכים.	זיהוי איומים מתקדם ותגובה ותגובה מקיפה בזמן אמת.
רמת אוטומציה	מוגבלת (דורשת הגדרות ידניות).	גבוהה מאוד (מבוססת תסריטי Playbooks).	אוטומציה מובנית לתגובה מהירה.
תרחיש אידיאלי	סביבות מורכבות הדורשות נראות מלאה ודוחות רגולציה.	צוותים עמוסים הזקוקים לייעול וחסכון בזמן ידני.	ארגונים המחפשים פלטפורמה אחודה להגנה אקטיבית.

מרכז הבקרה: כך נראה דשבורד SIEM חכם

מפת חום
זיהוי ויזואלי מהיר של
חריגות בתעבורת הרשת או
ריכוז התחברויות חריג.

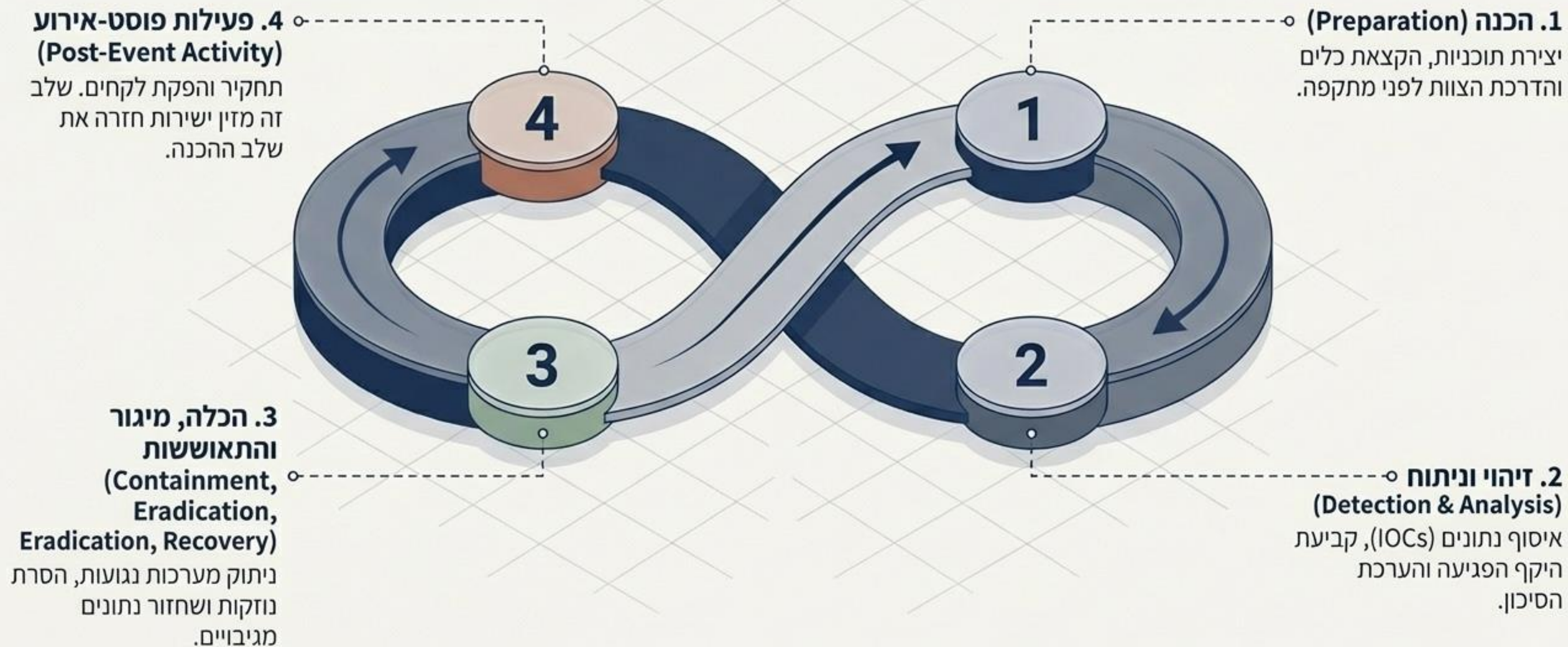
תיעדוף התראות
בינה מלאכותית מסווגת
התראות ודוחפת את
האירועים הקריטיים לראש.



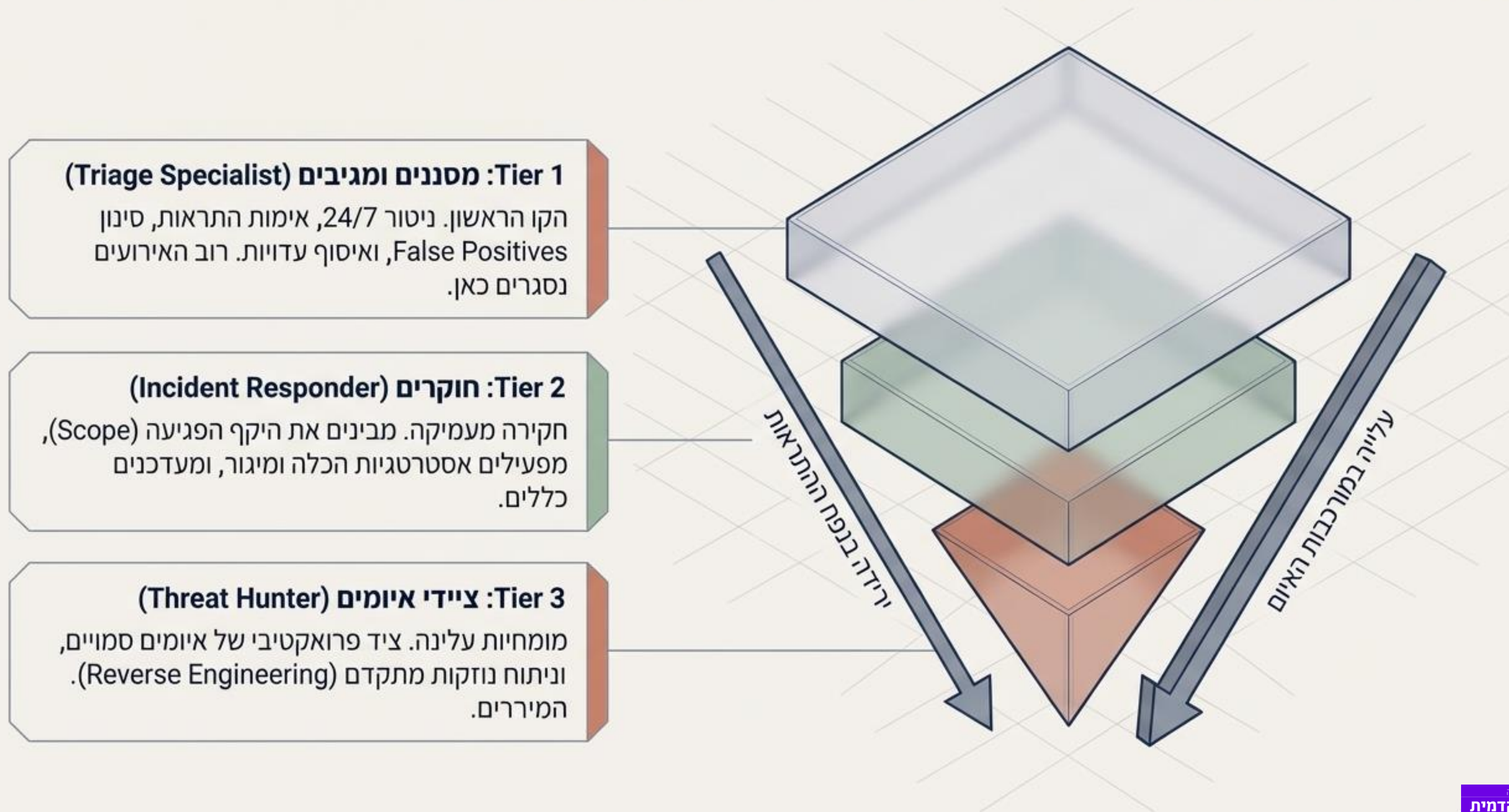
ניתוח התנהגות (UBA)
יצירת קו בסיס (Baseline)
לכל משתמש כדי לזהות
זהויות שנגנבו.

שילוב מודיעין
(Threat Intelligence)
הזנת נתונים בזמן אמת על
כתובות IP ונוזקות מוכרות.

מחזור החיים של תגובה לאירוע (NIST Framework)



היררכיית האנליסטים: מודל שכבות ה-SOC



תרחישי שימוש מובילים (Top SOC Use Cases)

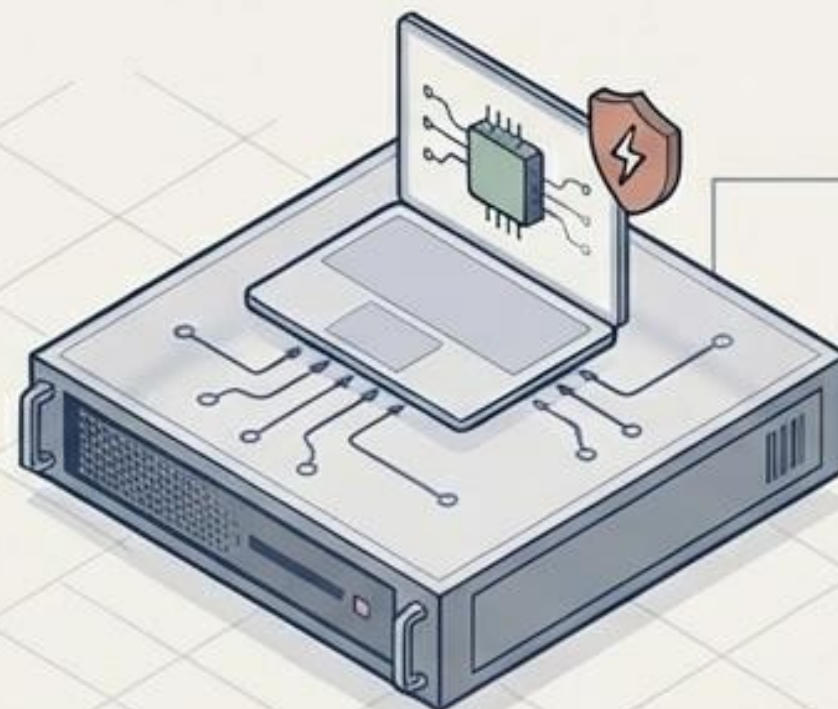
ציד איומים פרואקטיבי (Threat Hunting)

סריקה אקטיבית לאיתור תוקפים "שקטים" שהצליחו לעקוף את מערכות ההגנה הסטנדרטיות.



ניהול אירועי תחנות קצה (EDR Alert Triage)

ניתוח והגבה מהירה להתראות מתחנות קצה כדי למנוע התפשטות **כופרה** (Ransomware).



טיפול בפישינג (Phishing Triage)

אוטומציה לבידוד קבצים ולינקים זדוניים שנשלחו במייל, טרם לחיצת המשתמש.



תגובה לאירועי סייבר (Incident Response)

זיהוי חדירה והפעלת פרוטוקול **בלימה בזמן אמת** למזעור **נזק עסקי**.



מעבר מפעילות לתוצאות: מדדי ההצלחה של ה-SOC



Mean Time to Detect

הזמן החולף מרגע החדירה לרשת ועד הזיהוי. המטרה: צמצום למינימום.



Mean Time to Respond

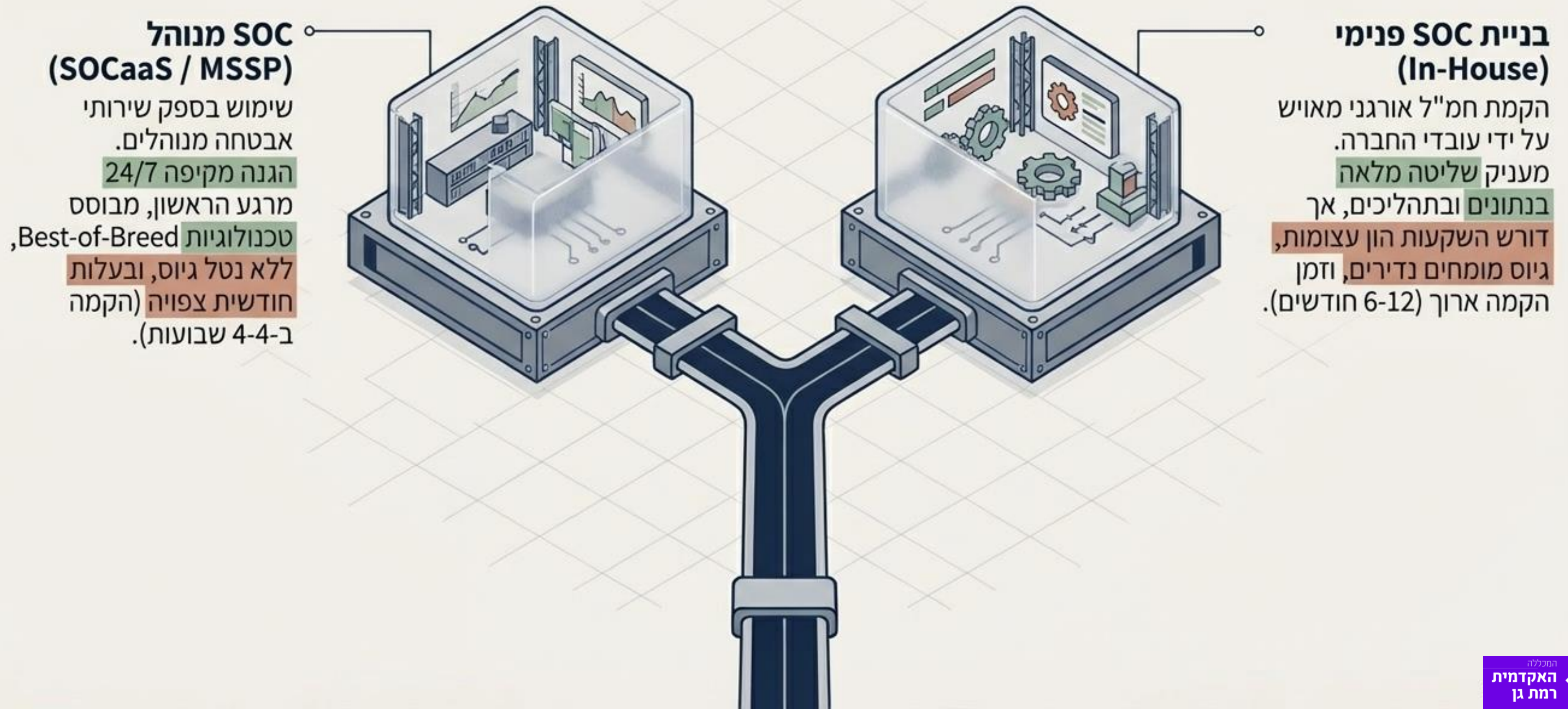
הזמן שלוקח להכיל ולנטרל את האיום. שילוב SOAR מוריד SOAR מוריד נתון זה דרמטית.



Alert-to-Incident Ratio

מודד דיוק. SOC בוגר יציג נפח נמוך של התראות עם אחוז גבוה של אירועי אמת, לעומת אלפי התראות שווא.

הדילמה האסטרטגית: לבנות פנימה או להוציא החוצה?



מטריצת קבלת החלטות (Deployment Strategy)

פרמטר	SOC פנימי (In-House)	SOC מנוהל חיצוני (SOCaaS)
זמן להפיכה למבצעי (Setup Time)	חודשים ארוכים (6-12 חודשים) 	שבועות בודדים (4-8 שבועות) 
זמינות מומחים 24/7	נטל גיוס ושימור עצום עצום על הארגון 	כלול באופן מובנה בשירות 
חיזוי עלויות (Cost Predictability)	משתנה (תלוי שחיקה ושדרוגים) 	קבוע מראש (Fixed) 
התאמה אישית ושליטה	שליטה מוחלטת, כתיבת כתיבת חוקים פנימית 	רמה בינונית-גבוהה, שיתוף עם הספק 
פרופיל ארגוני אידיאלי	ארגוני ענק או מוסדות ביטחוניים 	רוב החברות (SMB עד Enterprise Enterprise) 

מודל האחריות המשותפת ב-SOCaaS

אחריות ספק ה-SOC (MSSP)

- ניטור שוטף 24/7 ותחזוקת פלטפורמות.
- ביצוע טריאז' לאירועים וסינון התראות שווא.
- **בלימה טקטית של האיום** (למשל, בידוד תחנה).

אחריות הלקוח (הארגון)

- הגדרת רמת סיכון ותעדוף השפעה עסקית.
- אישור סופי לפעולות דרסטיות.
- **טיפול בתיקון שורשי ארוך טווח** בתשתיות ה-IT.

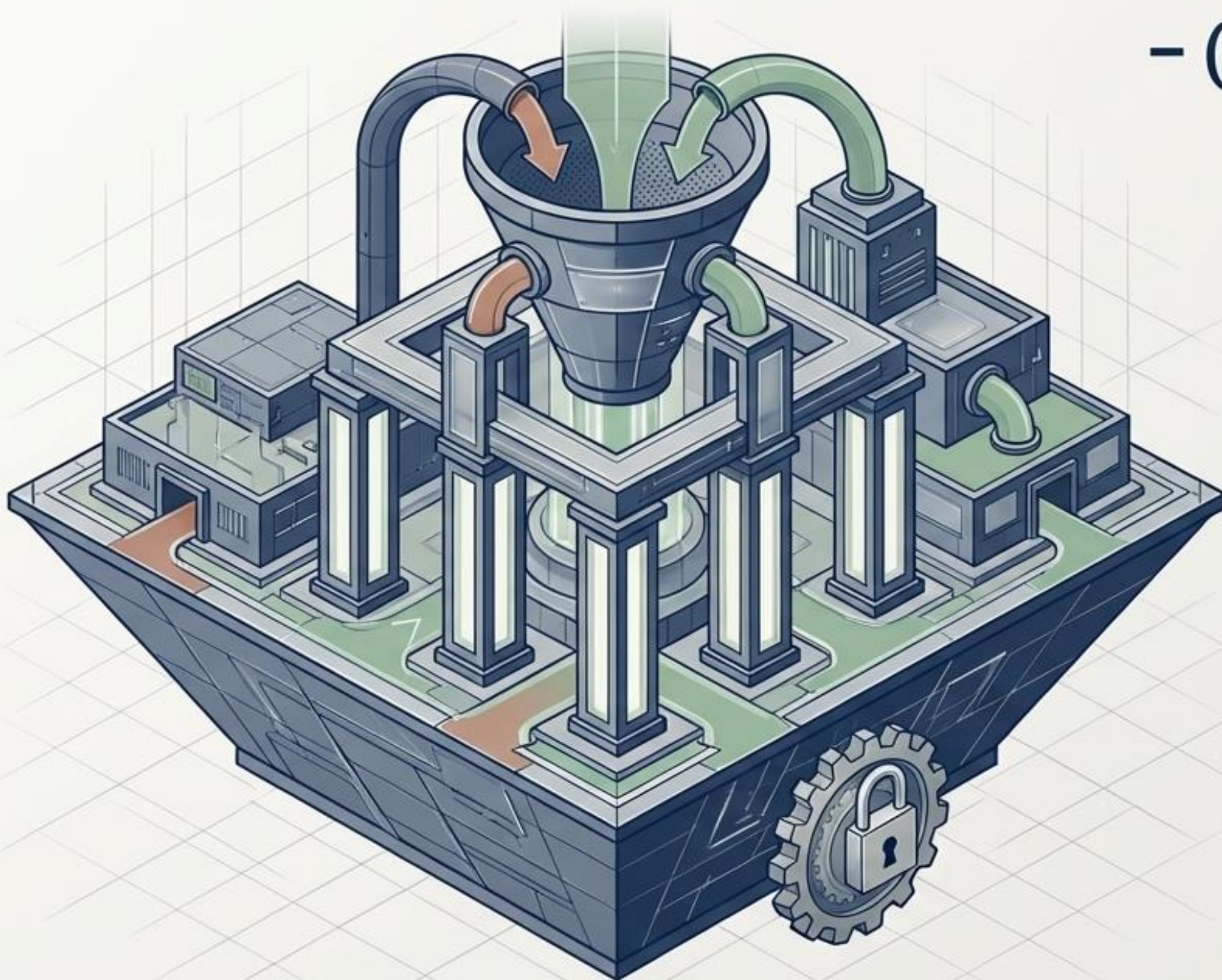
הלקוח צורך תוצאות (הגנה והנחיות), לא התראות.

מעבר לנראות (Visibility) – חמ"ל הסייבר המודרני כבסיס לפעולה

בניית Security Operations אינה
פרויקט חד-פעמי, אלא מסע מתמשך
של בניית חוסן ארגוני
(Resilience).

על ידי שילוב נכון של השילוש הקדוש
(אנשים, תהליכים וטכנולוגיות),
ארגונים הופכים "רעש" מידע לפעולה,
ואיומי סייבר – לסיכונים מנוהלים.

בין אם תבחרו לבנות פנימה או לצורך
כשירות (SOCaaS), מרכז שליטה
אפקטיבי הוא הערובה היחידה
להישרדות ולשגשוג במרחב הדיגיטלי
המודרני.





המרכז לניהול אירועי אבטחה (SOC) בעידן ה-AI

מאוסף רסיסים לתמונה
ארכיטקטונית שלמה: בניית
מערך הגנה מונע סוכנים
(Agentic AI) חכמים

נקודת השבירה של מודל ה-SOC המסורתי



שטחים מתים

40%

מההתראות נותרות
ללא חקירה

[מקור: PwC]



עומס נתונים

10,000+

התראות אבטחה
בממוצע ביום

[מקור: PwC]



מחיר הכישלון

60% מהארגונים

חוו פריצה
כתוצאה מהתראה
שפוספסה או דוכאה
[מקור: PwC]



שחיקת צוותים

71%

מאנשי ה-SOC
מדווחים על שחיקה
חמורה
[מקור: PwC]

שינויים קוסמטיים לא יספיקו; נדרשת חשיבה ארכיטקטונית מחדש.

שורש הבעיה: קריסת הקונטקסט (Context Collapse)

מציאות עסקית



הפער הסמנטי



טקסונומיה גולמית

המגבלה הביולוגית: המוח

המוח האנושי אינו בנוי לחבר קודע מבודדות מתוך פטק-ניטה-בייטים של לוגים גולמיים.

עייפות התראות:

Alert Fatigue היא מכבסת מילים. זו אינה עייפות פיזית, אלא פשיטת רגל כגד קוגניטיבית מול קצב הנתונים.

הפער הסמנטי:

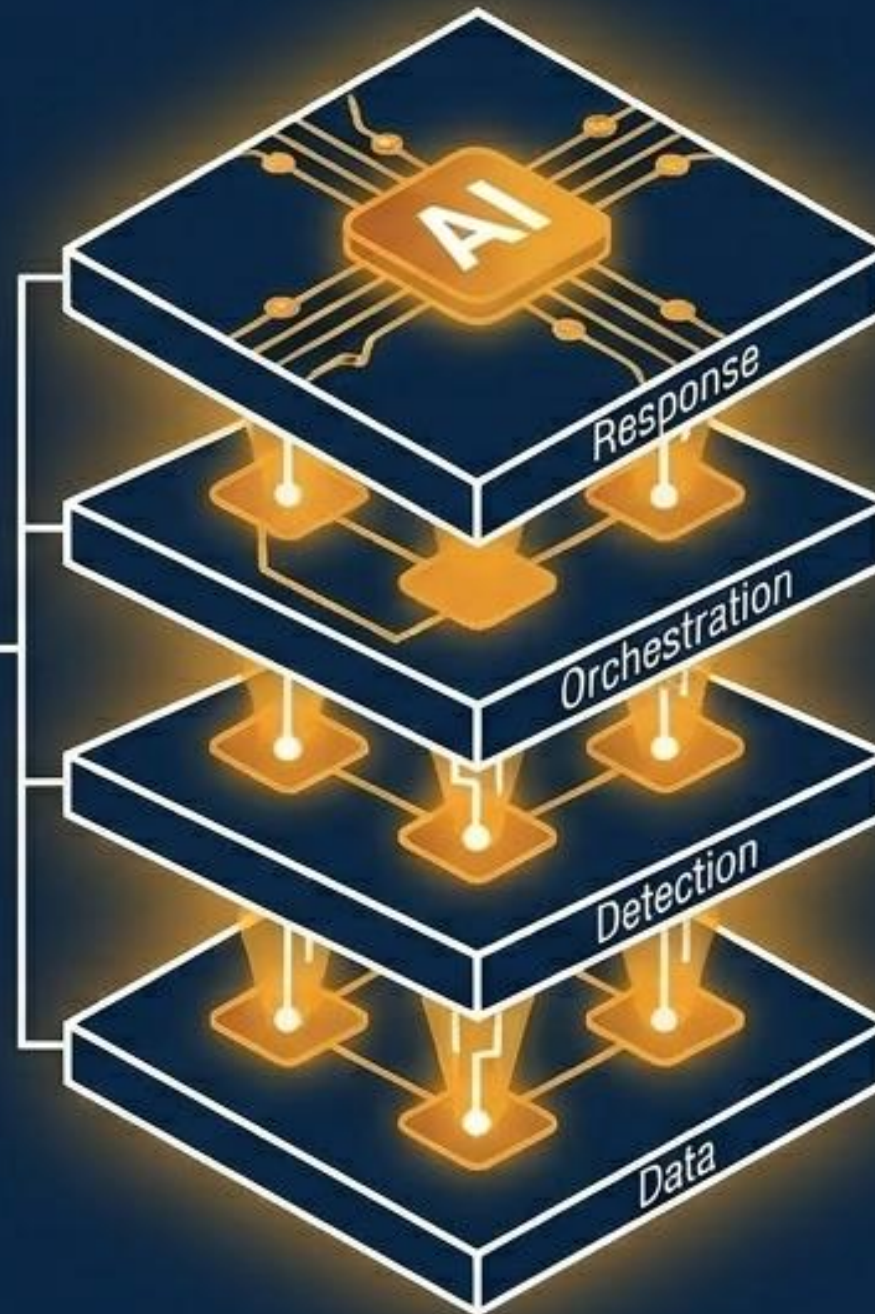
המרחק העצום שבין שורת קוד ב-Firewall לבין המשמעות המשמעות העסקית של האירוע. כאן, התוקפים מנצחים.

שינוי פרדיגמה: מבוט פטפטן לארכיטקטורת ליבה

AI כשכבת צ'אט



AI-Native SOC

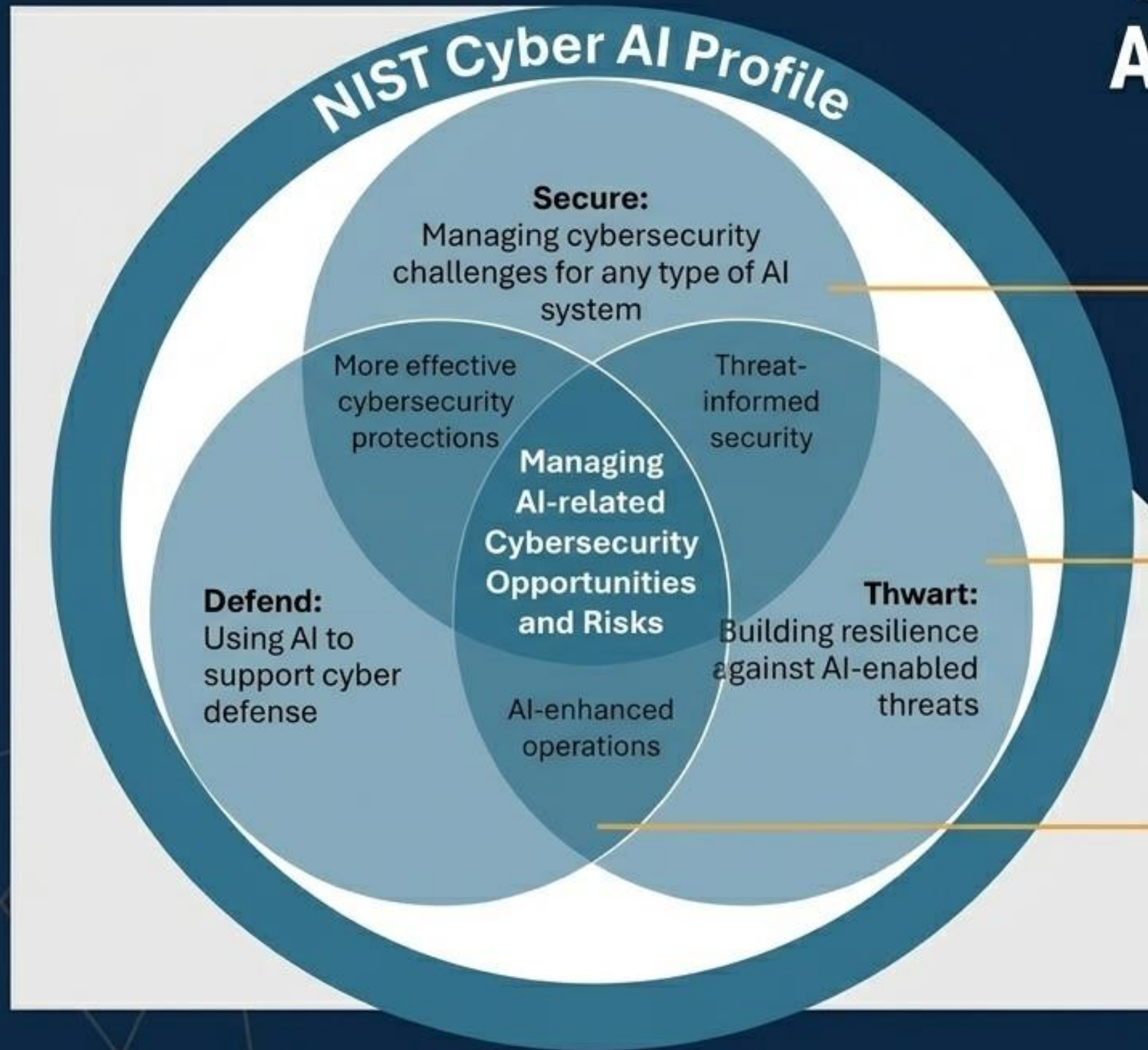


- לא רק צ'אטבוט (Copilot a Not just): מערכת שמסוגלת לחקור עצמאית (Agentic AI) ולא רק לסכם טקסטים.

- תגובה אוטונומית: טיפול ב-90% ממשימות Tier-1 ברמת המכונה [מקור: PwC].

- העצמת האנליסט: העברת משקל מחקירה סיזיפית לקבלת החלטות אסטרטגיות (Human in the Loop).

מסגרת העבודה של NIST: הוליסטיות בניהול סיכוני AI



Secure (הגנה על ה-AI):
אבטחת מודלים, נתונים
ותשתיות ה-AI של הארגון.

Defend (הגנה באמצעות AI):
שימוש בבינה מלאכותית לייעול
תהליכי גילוי, חקירה ותגובה בסייבר.

Thwart (סיכול איומי AI):
בניית חוסן ארגוני מפני תוקפים
הממנפים AI (Deepfakes)
(Deepfakes) אוטומציה זדונית).

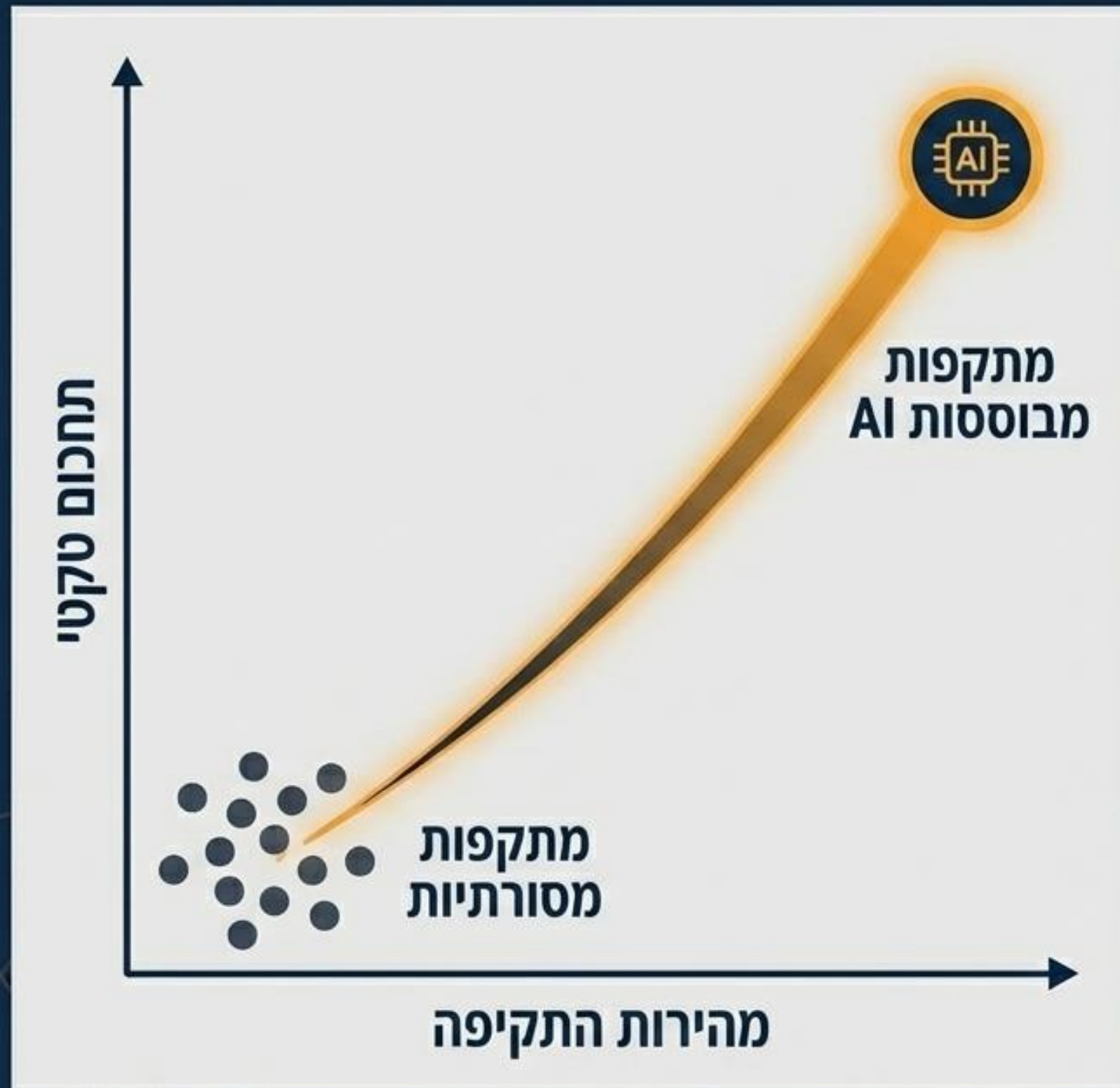
Thwart: התמודדות מול לוחמת סייבר אסימטרית

תיאור מקרה:

- **האירוע:** גניבת 200 מיליון דולר הונג קונגי מתאגיד רב-לאומי.
- **הווקטור:** הונאת Deepfake בזמן אמת בשיחת וידאו, תוך התחזות להנהלת החברה.

האתגר המרכזי:

תוקפים משתמשים ב-AI כדי להעלים חתימות, לייצר דיוג (Phishing) בקנה מידה עצום, ולנוע ברשת במהירות של מכונה. ההגנה חייבת להתנהל באותו קצב.



Defend: הארכיטקטורה העצבית של ה-SOC העתידי



4. The Memory (Pinboards)
יצירת רצף חקירתי ושימור הסטייט (State)
בין משמרות ואנליסטים.

3. The Orchestrator (Intent-Based SOAR)
קבלת החלטות אקטיבית מבוססת מטרות
(Promptbooks).

2. Context Hub (MCP)
שבירת ה-Silos וחיבור המידע באופן רציף
בין המערכות.

1. Telemetry Plane (Data Lakes):
איסוף נתונים גולמיים ונירמול (ASIM).

שלב 1: נירמול הרעש (ASIM) כבסיס לכל החלטה

רעש גולמי

```
{
  "timestamp": "2023-10-27T10:05:23.123Z",
  "event_id": "12345",
  "source_ip": "192.168.1.100",
  "dest_ip": "10.0.0.5",
  "user": {
    "timestamp": "2023-10-27T10:05:23.123Z",
    "event_id": "12345",
    "source_ip": "192.168.1.100",
    "dest_ip": "10.0.0.5",
    "user": "john.doe",
    "action": "login_attempt",
    "result": "failed",
    "raw_message": "..."
  },
  "raw_message": "..."
}
```

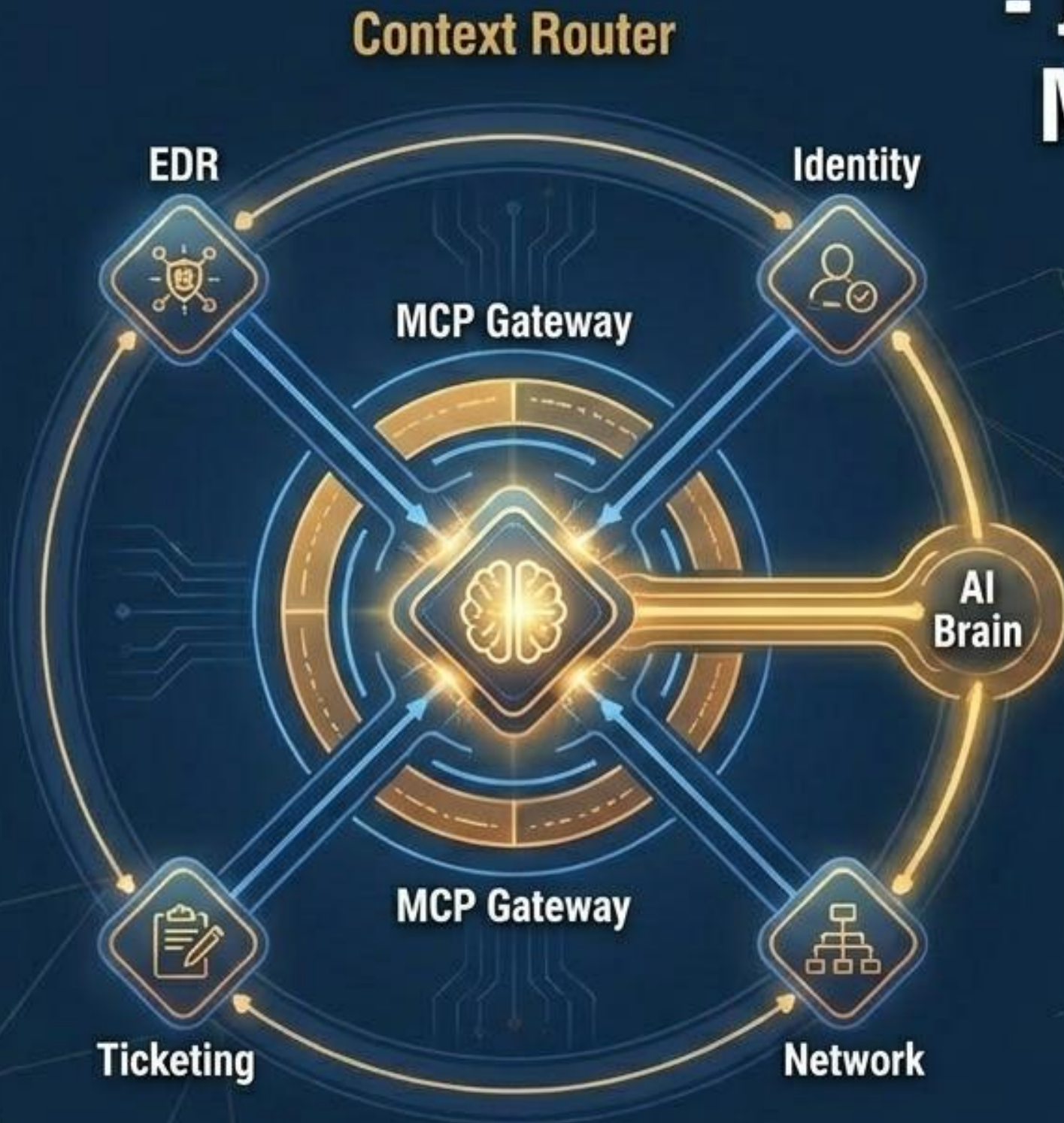
נירמול נתונים

קונטקסט סמנטי

אירוע	
סוג: כניסה כושלת	
זמן: 27/10/2023 10:05:23	
ישות מקור	
משתמש: john.doe	
כתובת IP: 192.168.1.100	
ישות יעד	
כתובת IP: 10.0.0.5	
תוצאה	
סטטוס: נכשל	

- מודלי AI מתקשים ולעיתים הוזים (Hallucinate) מול טקסט גולמי ולא מובנה.
- מודל נתונים כמו ASIM הופך שורת קוד סתמית לישות ברורה (למשל: Source IP או Target User).
- נירמול המידע חוסך משאבי חישוב יקרים (Tokens) ומונע את עיוורון המערכת בשלבי החקירה.

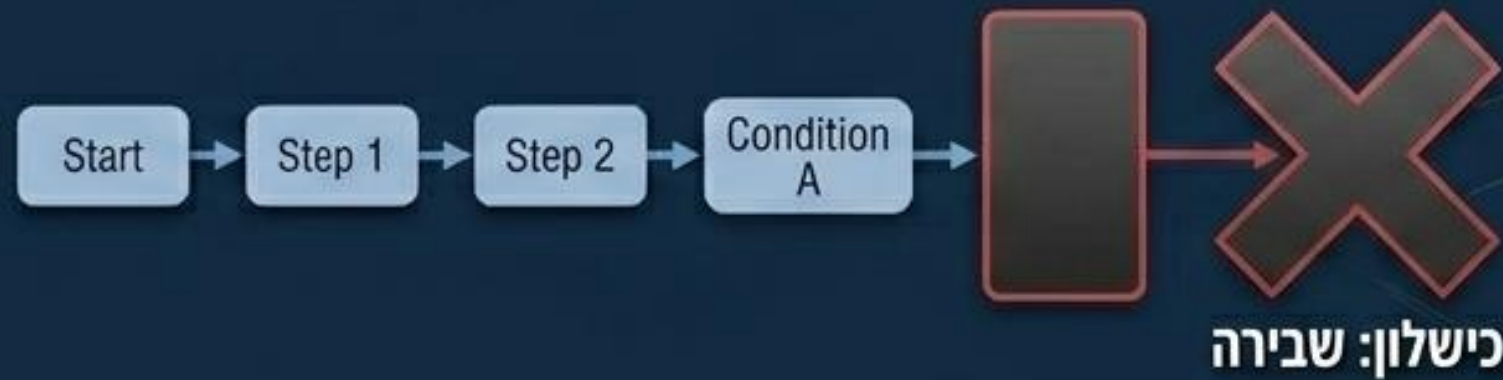
שלב 2: מערכת העצבים המרכזית - Model Context Protocol (MCP)



- אנליסטים מבזבזים כ-80% מזמנם במעבר חלונות (Alt-Tabbing) ובהעתקת נתונים - פעולה שמשמידה קונטקסט.
- פרוטוקול ה-MCP מייצר סטנדרטיזציה טכנית: ה-AI יכול לבקש פרופיל סיכון למשתמש ולקבל תשובה אחידה מכל הכלים במקביל.
- ה-MCP הוא הצינור שדרכו זורם הדם של החקירה מקצה לקצה, ללא פעולות המרה ידניות.

שלב 3: סוף עידן הפלייבוק הנוקשה - Intent-Based SOAR

ליניארי SOAR



• הבעיה בפלייבוקים המסורתיים: נשברים כשהתוקף משנה את הטקטיקה במילימטר; חסרי קונטקסט דינמי.

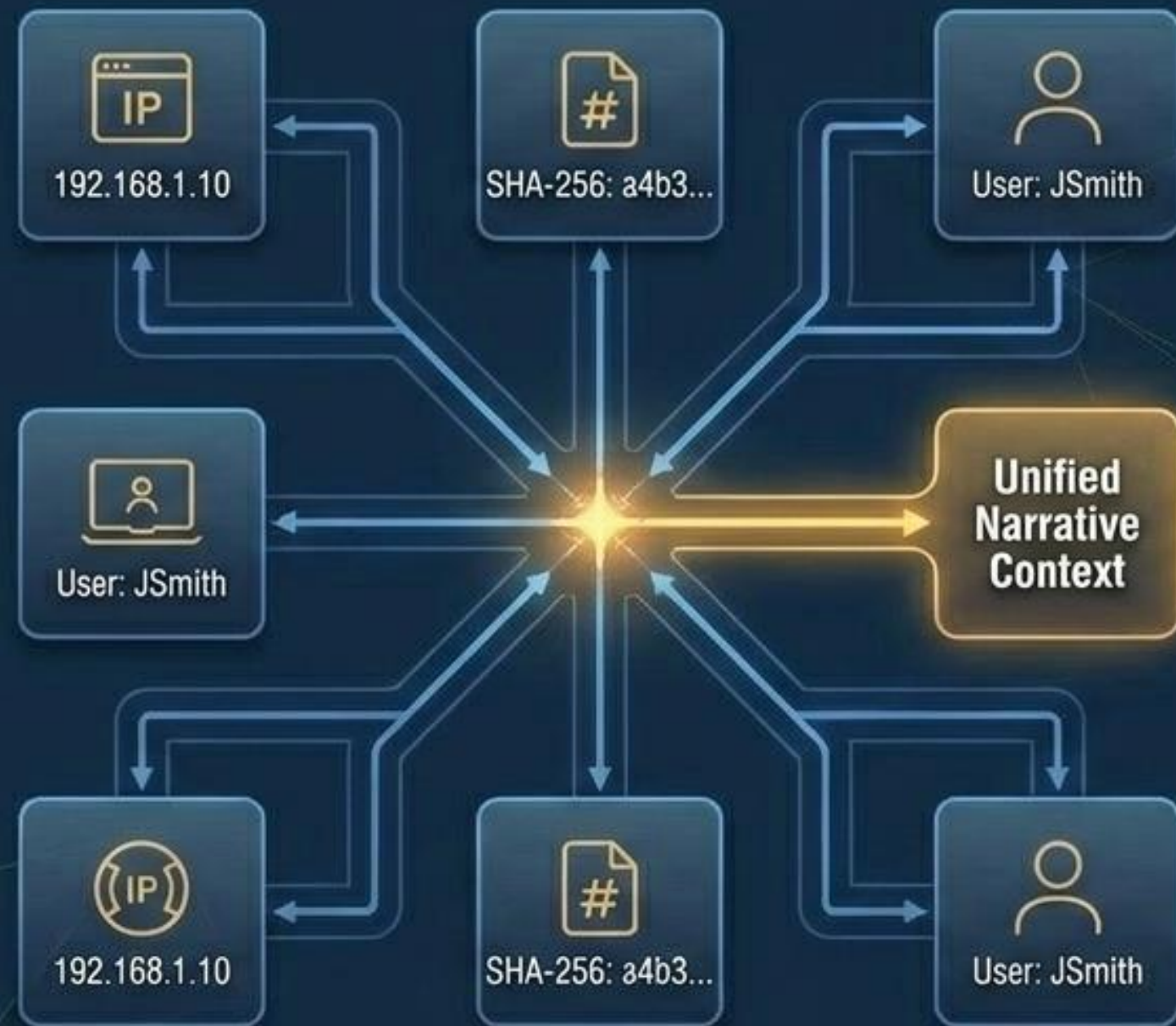
SOAR מבוסס כוונה



• הפתרון (Promptbooks): מתן מטרת-על (Objective) למודל – חקדור וזהה תקיפת כופר.

• ה-AI סורק את המידע דרך ה-MCP, מקבל החלטות בזמן אמת, ויודע מתי לסטות מהמסלול ולעצור אם התגלה כי מדובר בפעילות לגיטימית.

שלב 4: מנוע הזיכרון ארוך הטווח (Pinboards)



• נקודת התורפה הקריטית בסוק היא העברת המקל בין חוקרים - איבוד הסטייט (Statelessness).

• לוח הסיכות (Pinboard) משמש כ-Context Store של הסשן החקירתי.

• המערכת שומרת ומצליבה עדויות, ארטיפקטים והערות לאורך זמן - והופכת רצף אירועים אקראיים לסיפור חקירתי רציף (Narrative Context).

הגורם האנושי: הזרקת הקשר עסקי למערכת (Context Injection)



- המכונה יודעת הכל על הנתונים, אך עיוורת לחלוטין לפוליטיקה ולמציאות העסקית של הארגון.
- תפקיד האנליסט משתדרג מפענוח לוגים למזריק ידע למערכת באמצעות כלים יומיומיים.
- ניהול כרטיסים (Jira) כמאגר אימון: סגירת טיקט בפירוט משמשת לאימון (RAG) לזיהוי עתידי של פעולות לגיטימיות.
- Watchlists: תיוג נכסים רגישים כדי לצרוב קונטקסט קשיח לזיכרון ה-AI.

המדד החדש להצלחה: מ-MTTC ל-MTTC (Mean Time To Context)

SOC מסורתי

תגובה

זמן פענוח ידני ואיתור מידע

90%

10%

AI-Native SOC

10%

MTTC

זמן החלטה ותגובה

90%

זמן גילוי ראשוני (MTTD) כבר אינו מספיק; המדד הקריטי החדש הוא זמן בניית ההקשר (MTTC).
בסוק מסורתי: הרכבת תמונת המצב אורכת ימים או שבועות.

ב-AI SOC: המערכת מחברת את הנתונים דרך ה-MCP וה-Copilot ומגישה תמונה מלאה לאנליסט בתוך דקות.

הניצחון שייך לארגון שמייצר קונטקסט מהר יותר מהיריב.

המהפך התפעולי: השוואת מדדי ביצוע

(KPI Matrix)

מדד	SOC מסורתי	AI-Native SOC
נפח מול קיבולת (Alert Volume)	40% מוהתראות מתעלמים מהן	קומפרסיה של 90-99% ברעש, 100% מהתראות נבדקות ראשונית [מקור: PwC]
זמן תגובה (MTTR)	נמדד בשעות ובימים	נמדד בדקות ואף בשניות
פרודוקטיביות (Productivity)	שחיקה מסיבית	גידול של פי 3 עד פי 5 ביעילות הצוות הקיים
רזולוציה אוטומטית	פחות מ-5%	טיפול אוטונומי קצה לקצה ב-20%-40% מהאירועים

מפת הדרכים: המעבר לאופרציה מונעת AI

4. שדרוג האנליסט:

שינוי הגדרות תפקיד - מ-קורא לוגים ל-מזריק הקשר עסקי וקבלת החלטות אקטיבית.

3. שבירת חומות וחיבור: פריסת ממשקי MCP (MC/Model Context Protocol) בין מערכות האבטחה לליבת החקירה.

2. יישום מסגרת עבודה: אימוץ מודל NIST לניהול גבולות ה-AI והגדרת הרשאות קשיחות ל-AI-Agent.

1. איחוד הנתונים: מעבר לארכיטקטורת Data Lake ויישום מודלי נירמול (ASIM).
אי אפשר לאמן AI על מידע מזהם.

במלחמה על המהירות והדיוק, הקונטקסט הוא המלך, וה-AI SOC הוא הממלכה.

שאלות ?

